



Threat Analysis

Classification

INTERNAL

Table of contents

- [Abstract](#)
- [Objective](#)
- [Standard references / overarching requirements](#)
- [Terms / Explanations / Definitions](#)
 - [Device classification](#)
 - [Type definition according to IEC EN 62443-4-2:](#)
 - [Additional Type Definitions:](#)
 - [Resources and Assets](#)
 - [Data classification](#)
 - [Memory Classification \(Volatility Document\)](#)
 - [Other Component Properties](#)
 - [Exposure:](#)
 - [Communication Skills/Access:](#)
 - [Determination of protection objectives based on risk assessment](#)
 - [Determination of protection objectives](#)
 - [Classification of the protection goals:](#)
 - [Definition of attackers and their motivation:](#)
 - [Overview of life phases and tasks](#)
 - [Boundaries of trust of the SUC](#)
- [Global Endangerment List](#)

- [Determination of measures based on the protection objective and threats](#)
- [Specifications / Requirements](#)
 - [Setting the System under consideration \(SUC\)](#)
 - [Clear identification and description of the system](#)
 - [Determination of the limits of low-voltage equipment](#)
 - [Classification of the SUC](#)
 - [Device classification](#)
 - [Data classification](#)
 - [Definition of the operating environment of the SUC \(exposure\)](#)
 - [Definition of communication options and access requirements](#)
 - [Documentation](#)
 - [Consideration of the SUC and all interfaces for possible vulnerabilities according to the following threats \(STRIDE method\)](#)
 - [Example](#)
 - [Diagram Threat and Risk Analysis \(High-Level and Detailed Observation \)](#)
- [Change history](#)
- [Contributors](#)

Threat analysis

Abstract

Definition of the requirements for the extension of threat analysis for CE conformity assessment. The document defines the necessary component characteristics, determines protection goals and threat vectors.

Objective

The aim of the document is to expand the risk analysis based on the IEC EN 61010 to include the requirements of cyber security.

Standard references / overarching requirements

The following standards and guidelines are the basis for threat analysis and risk assessment:

CENELEC Guide 32:2014 [IECSTD - Version 3.2](#)

IEC EN 62443 series in the current version

IEC IEC 62351-8

[Volatility Document - Where can I find volatility documents? -NI](#)

[Guidelines for Media Sanitization](#) (NIST SP800-88r1)

[BSI - Elementary Threats](#)

Common Attack Pattern Enumerations and Classifications  [CAPEC - Common Attack Pattern Enumeration and Classification \(CAPEC™\)](#)

[Understanding the Relationship between CWE and CAPEC Through Two Scenarios](#) | [by Edwin Covert](#) | [Medium](#)

Terms / Explanations / Definitions

Device classification

In addition to the description of the system, a generic device class is assumed. Device class determination helps determine requirements and responsibilities

Type definition according to IEC EN 62443-4-2:

- **Network Device**

Devices whose main purpose is data transmission or data filtering, e.g. switches, VPN endpoints, firewalls (the devices are not directly involved in the control of the system)

- **Embedded Device**

Industrial control (e.g. PLC), which is programmable. Also includes smart sensors and actuators that process measurement data. (Note: no accessible operating system, the hardware product manufacturer is responsible for updates)

- **Host Device**

Workstation computers or servers in an industrial environment with standard operating systems (Windows, Linux, open operating systems, the operator keeps his system environment up to date). Also includes log servers

- **Software Application:** Programs and the associated data

(Note: the software usually runs on embedded devices or host devices)

Additional Type Definitions:

- **Embedded sensor / actuator with analog, digital interface**

Devices that transmit physical measurands electrically in the form of analog signals 4 - 20mA or digitally or process signals unchanged and not pre-processed

- **Embedded sensor / actuator with fieldbus interface (protocol-based), incl. IO-Link protocol**

Devices that pre-process physical measurands and pass them on in a standardized, described form or process signals

- **Input/Output Modules:**

- **Decentralized communicative IO modules:**

- AS-i Slaves (not AS-i Master)
- IO-Link Devices (not IO-Link Master)
- CAN I/O Module (not CAN Gateways)

- **Communication modules**

devices intended for their intended use, the provision of communication interfaces such as wireless communication or additional wired

Resources and Assets

The following resources and assets must be documented and considered in the threat analysis. In a threat analysis, the term "assets" refers to any valuable assets that need to be protected. All resources whose compromise can have an impact on availability, integrity and confidentiality, or represent a business risk for the manufacturer, are worthy of protection. Resource and assets could be, for example:

- Data
- Applications, such as web server applications
- Databases
- Intellectual property, software code worthy of protection
- Access data, key material

Data classification

- **System**

General system data that is not related to a specific person or is not security-relevant. This type of data has no impact on the availability, integrity or confidentiality or impact on the safety of any person.

- **Sensitive system data**

Data that is not related to a specific person and has no relevant impact on security, but with a significant potential for financial or other harm or impact on the user's security if the

availability, integrity and confidentiality of the data is compromised. This includes, for example, confidential business information or recordings from surveillance cameras.

- **Personal**

General data concerning a specific person without causing significant potential harm to the user if the availability, integrity and confidentiality of the data is compromised. This includes, for example, names and public photos.

- **Sensitive personal data**

Data that concerns a specific person and that causes significant potential harm to the user if the availability, integrity and confidentiality of the data is compromised. This includes health data, private messages, and personal financial information

- **Security**

Security-related data that is not related to a specific person, but with significant security implications if the availability, integrity, and confidentiality of the data is compromised. This includes, for example, passwords, security-critical configuration

- **Sensitive security data**

Security-related data unrelated to a specific person, but with significant implications for the security of the TOE and other products if the integrity and confidentiality of the data is compromised. These include, for example, master keys

Memory Classification (Volatility Document)

Volatility documents document the locations for volatile and non-volatile data in a hardware device. This information is necessary to protect devices when they are removed for repair, reallocation, or disposal to ensure that data is not inadvertently made available to other people. In accordance with the requirements of NIST SP800-88r1 (Guidelines for Media Sanitization, NIST 800-88), appropriate measures are necessary for the secure deletion of data/information.

Volatility documents include the following sections:

- Modules Covered – Product variants to which the volatility document applies.
- Volatile Memory – Locations for data lost when turned off and on.
- Non-volatile memory – Locations for data that are retained even when power is turned off and on.

The memory lists include information about whether the storage location has a battery backup and whether it is user- and system-accessible. The lists also include a description of the deletion process for each location. Deletion instructions are documented as procedures.

Procedures can be physical actions such as disconnecting a backup battery. A procedure can consist of a series of function calls that can be used to delete the data.

Other Component Properties

- **Communication over insecure networks (zone transition)**

Insecure networks are usually topologies that are not the responsibility of the component manufacturer, integrator or operator. This includes mobile phone connections and other wireless connections that are not the administrative responsibility of the operator. Furthermore, this includes all connections provided by service providers.

- **Users in the life cycle of the system**

When looking at the lifecycle, all users who interact with the system must be recorded and associated access rights must be determined. The aim of this provision is to reduce the impact on the availability and integrity of the system due to incorrect operation by operating personnel. An overview of operating personnel can be found in IEC IEC 62351-8.

- **Data persistence on the system**

In addition to parameter and configuration data, it should be determined whether customer data is stored on the system. Based on the respective phases of the life cycle, separate requirements must be determined.

Exposure:

After the system has been determined and described, the position (exposure) is determined.

- **Zone Level 4: Enterprise / Intranet of the operator**

This zone describes the office IT environment of the operator including the transition to the ISP network or Internet access. User endpoints and central instances (servers, virtual and physical) are operated in this zone. The systems are subject to regular updating and short operating times (user terminals ≤ 4 years). Program updates are also the rule here, usually within the framework of 2 years. The main protection goal of this layer is the confidentiality of information. This is followed by integrity and concludes with availability. The background to this is the high data density and mostly business-critical information and customer data. Availability is rated lower because critical systems are usually designed redundantly and the availability of workstation systems can be intercepted by shifting the activity to other wards. The environment is usually divided and segmented across the organization. These include closed office workstations as well as comprehensive access restrictions at the file and information level. The systems in the enterprise level are usually connected to the Internet and access to web resources is one of the regular activities of the employees. In smaller

environments, regular updates are carried out automatically by the systems directly from the Internet.

- **Zone Level 3:** OT network of the operator

This subcategory describes a network section (can contain several segments) for production-related IT systems. The OT network is separated from the IT network by network-side solutions. The transition from IT to OT determines the change in protection goals from CIA (Confidentiality-Integrity-Availability) to AIC (Availability-Integrity-Confidentiality). The systems at this level are indirectly directly linked to the value creation of the company. Failures at this level usually have a direct impact on production processes. The runtime of the central OT systems is longer than at level 4 and regular updates of the operating environment are carried out rather rarely and are associated with high effort and costs. A direct internet connection is usually not available. Updating the systems in the OT network is usually carried out manually within the framework of scheduled maintenance windows. The systems in the OT network may be restricted or accessible. Production-related systems are accessible and can be operated by changing personnel.

- **Zone Level 2:** Production or machine network of the operator

A segment of the OT network that contains a part of the value chain or covers a sum of processes. Components within a Zone Level 2 have the same protection objective. Zone 2 groups together systems of a production line or area. This level provides remote maintenance access for machine manufacturers. In addition, systems of a machine are grouped together in this level. This segmentation is usually distinguished from other systems by micro-segregation firewall systems.

- **Zone Level 1:** Fieldbus level (below the production network)

At the fieldbus level, all components that are connected exclusively via fieldbuses are combined. Systems at Level 1 communicate via proprietary protocols. The main characteristic of this communication is a fast or deterministic runtime. The availability of the transmitted data is a fundamental component of these systems.

All levels shown here are delimited by "Trust Boundaries". All systems within a zone should have the same security requirements, respectively. provide.

Communication Skills/Access:

The intended use can determine the ability to communicate and the accessibility. This results in requirements for the strength of the protective measures provided and the necessary measures for access protection and the necessary communication.

- Component can be accessed directly from the operator network or from another zone with different security requirements

Components offer interfaces for incoming connections that are to be reached across zone boundaries. This includes published resources such as web or medium servers, ERP systems that must be accessible from the OT network, and VPN endpoints.

- Component has direct access to the Internet. Applies in conjunction with other classifications

Components can directly access resources that are outside of the customer's administrative responsibility. This includes, for example, components that connect PaaS or SaaS cloud solutions or carry out updates independently. The challenge here is that no malicious code can be loaded and executed and that sensitive data of all kinds is protected.

- Component/cabling is not accessible via the operator's network (Level 4). Access to external interfaces (USB, user interface) possible)
- Component communicates with other components in the operator network
- Component is not accessible via the operator network, but access to external interfaces (USB, user interface) is possible.
- The component is not accessible from the outside via the network and is protected from unauthorized access in the machine.

Determination of protection objectives based on risk assessment

The following assumption is used as a basis for determining the necessary protection objective:

Determination of protection objectives

The following definition is defined for the determination of the necessary **protection objectives**:

Security Level 1 (SL 1):

- **Objective:** Protection against accidental or unintentional breaches of security.
- **Description:** SL 1 includes basic security measures aimed at protecting systems from unintentional errors or accidental events. These measures are designed to reduce the likelihood of security incidents that could be caused by human error, technical errors, or other random events.

Security Level 2 (SL 2):

- **Objective:** To protect against deliberate breaches of security with simple means and few resources, general knowledge and low motivation.
- **Description:** SL 2 includes security measures aimed at protecting systems from opportunistic attackers who have basic knowledge and limited resources. These attackers often use easily

accessible tools and techniques to exploit vulnerabilities.

Security Level 3 (SL 3):

- **Objective:** Protection against deliberate breaches of safety with moderate means, special knowledge and medium motivation.
- **Description:** SL 3 includes security measures aimed at protecting systems from targeted attacks by attackers with specific skills and resources. These attackers have advanced technical knowledge and are willing to put in some effort to achieve their goals.

Security Level 4 (SL 4):

- **Objective:** Protection against deliberate breaches of security with advanced means, specialized knowledge and high motivation.
- **Description:** SL 4 includes comprehensive security measures aimed at protecting systems from sophisticated and targeted attacks by well-resourced and motivated attackers. These attackers have advanced technical skills and significant resources.

Classification of the protection goals:

Security Level 1 (SL 1)*: no longer sufficient in view of the threat situation for the majority of machines and systems. However, this level can also be chosen in individual cases as part of a risk analysis with appropriate justification, in particular for reasons of economic efficiency. In this context, a realistic weighing of implementation effort vs. risk of financial and other damage should always be carried out.

Security Level 2 (SL 2): Nowadays realistically achievable for components and de facto standard. Security Level 2 includes measures that can be provided by the component largely itself and without dependence on external systems.

Security Level 3 (SL 3)*: can already be assumed to be a real threat level in many areas today. However, if you take into account the processes with which machines and systems are actually built and operated today, we are still a long way from implementing SL-3 in many areas.

Security Level 4 (SL 4): Can only be achieved by using external components within a system.

**Note: Based on interpretations of the VDMA*

The definition of a static security level based on IEC EN 62443-4-2 is not recommended, as not all individual requirements of the respective "foundational requirement" (FR; IEC EN 62443-4-2). As a minimum of requirements, measures are taken into account that can be provided independently by the components or must be fulfilled by legal obligations. In individual cases, stronger measures are considered, the selection is based on the assumption of industry-

standard applications, the system environment provided and the expected care and maintenance effort on the part of the operator.

Definition of attackers and their motivation:

Script kiddies: These attackers use pre-built scripts or tools developed by others to exploit vulnerabilities in systems. They often have only basic knowledge and little motivation, but they can still cause damage.

Casual attackers: People who happen to encounter a vulnerability and exploit it without having specific knowledge or resources. Their attacks are often opportunistic and untargeted.

Insiders with limited knowledge: Employees or people within an organization who have access to internal systems but have limited technical knowledge. They could act out of dissatisfaction or curiosity. Employees or individuals with access to internal systems can intentionally or unintentionally cause security breaches. This can happen through dissatisfaction, financial incentives, or simply human error

Hacktivists: Activists who act for ideological reasons and often use simple methods to spread their messages or draw attention to their causes. Their resources and technical skills may vary, but they often use easily accessible tools. These groups carry out attacks for ideological reasons, to draw attention to certain issues or to exert political pressure. They often use simple methods to achieve maximum impact

Low-budget cybercriminals: Criminals who use low-cost or free tools and techniques to gain financial gain. They could use phishing attacks, simple malware, or social engineering

State-backed actors: Nation-states or state-backed groups carry out targeted attacks on critical infrastructure to gain political or economic advantage. These attacks are often very sophisticated and difficult to detect

Terrorists: Terrorist groups could attack OT systems to cause chaos or disrupt critical infrastructure. Such attacks can have a significant impact on public safety and the economy

Advanced Persistent Threats (APTs): These are sophisticated, long-term attacks that are often carried out by state-sponsored groups. They aim to penetrate a network and remain undetected in order to collect information or cause disruption over a longer period of time

Taking into account the technical framework conditions, actors from the group "**script kiddies**", "**occasional attackers**", "**insiders with limited knowledge**", "**hacktivists**" and "**cybercriminals with a low budget**" are assumed for the threat analysis. Due to the widespread use and the fact that industrial systems of all system depths cannot provide all necessary systems, threats and their actors who have basic knowledge and limited resources are taken into account. These

attackers often use easily accessible tools and techniques to exploit vulnerabilities. "**Insiders with limited knowledge**" are to be regarded as a critical group, as they usually have access to the application or machine. All other groups are dependent on infrastructural vulnerabilities or use vulnerabilities that can be attacked by misconfiguration, but which are not in the area of the components considered here. In addition, individual components alone cannot withstand sufficient protection against attacks by the groups "**state-supported actors**", "**terrorists**", "**advanced persistent threats (APTs)**". These groups usually use attack techniques on an infrastructure basis, which then have downstream effects on the individual components of a system.

Overview of life phases and tasks

When selecting the necessary cyber security protection functions, the following life phases and tasks according to CENELEC Guideline 32 are taken into account:

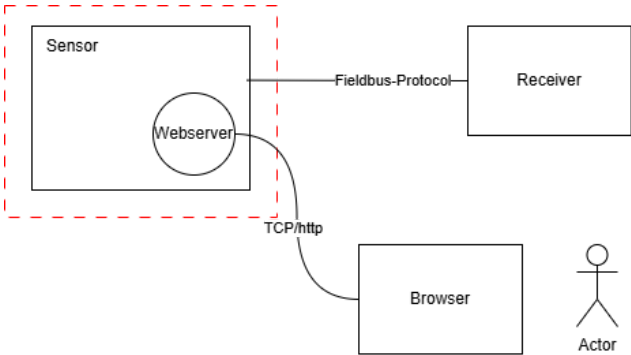
- Commissioning
 - Attitude
 - Examination
 - Programming
 - Hit
- Use
 - All operating modes
 - Troubleshooting/Troubleshooting
 - planned maintenance and repair
 - Unplanned maintenance and repair
 - System security threats (communication, access routes)
 - reasonably foreseeable misuse
- Decommissioning, dismantling and disposal, as far as safety is concerned
 - Removal of the product from the low-voltage equipment

Boundaries of trust of the SUC

The trust boundaries of a "system under consideration" determine the different areas of responsibility, the level of trust and at the same time the threats that can be considered within the scope of what is possible. A trust boundary marks the point at which the level of trust between different system components changes. At the beginning of the threat analysis, the necessary trust limits must be determined.

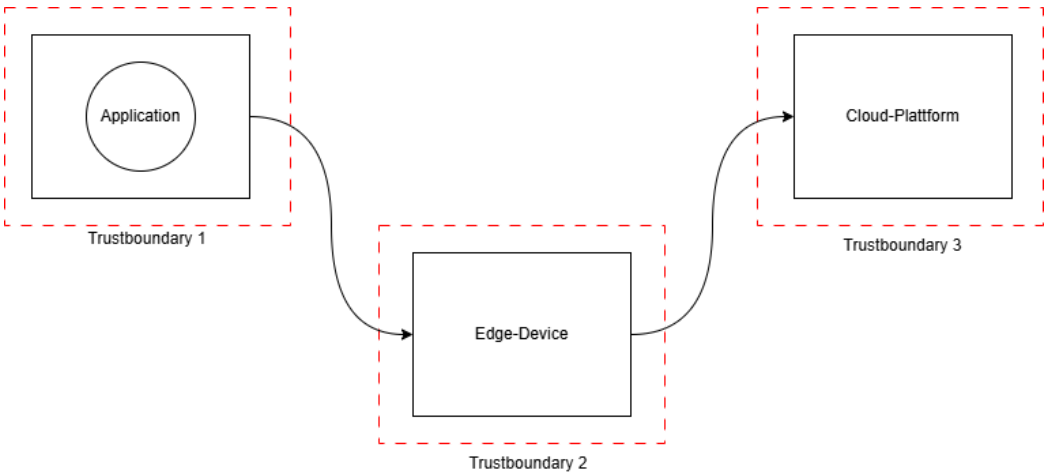
Example 1, simplified:

The example shown here distinguishes the sensor from the other entities. Since we are not responsible for the browser and the receiver and do not know or can determine the necessary level of security, we distinguish the sensor from the other components. Threat analysis only includes elements within the trust threshold.



Example 2, simplified:

If different components are required to use a SUC as intended, separate trust boundaries may need to be defined.



In this case, each entity must be considered with its own trust limit, provided that they are under its own responsibility.

Global Endangerment List

Category	ID	Threat	Risk assessment	Protecti on objectiv e	Description Details
			CENELEC Guide 32 Referencing	Availabil ity (A)	CAPEC

				Integrity (I) Confidentiality (C) + (AAA)	
Environment	G 0.1	Fire	A.6.6		
Environment	G 0.2	Unfavorable climatic conditions	1.4.1 DIN EN 61010-1/-2-201		
Environment	G 0.3	Water	1.4.2f		
Environment	G 0.4	Pollution, dust, corrosion	1.4.1 h		
Environment	G 0.5	Natural disasters			
Environment	G 0.6	Disasters in the surrounding area			
Environment	G 0.7	Major events in the vicinity			
Denial of Service	G 0.8	Power failure or malfunction	A.6.12	Availability	
Denial of Service	G 0.9	Failure or disruption of communication networks		Availability	
Denial of Service	G 0.10	Failure or disruption of supply networks		Availability	
Denial of Service	G 0.11	Failure or disruption of service providers	Supply Chain	Availability	
	G 0.12	Electromagnetic interference radiation	11.6		
	G 0.13	Interception of compromising radiation	RED		

Information Disclosure	G 0.14	Spying on information (espionage)		Confidentiality	CAPEC - CAPEC-157: Sniffing Attacks (Version 3.9)
Information Disclosure	G 0.15	Eavesdropping		Confidentiality	CAPEC - CAPEC-157: Sniffing Attacks (Version 3.9)
Denial of Service	G 0.16	Theft of devices		Availability	CAPEC - CAPEC-507: Physical Theft (Version 3.9)
Denial of Service	G 0.17	Loss of devices		Availability	CAPEC - CAPEC-507: Physical Theft (Version 3.9)
	G 0.18	Incorrect planning or lack of adaptation			Customer-side change management process
Information Disclosure	G 0.19	Disclosure of sensitive information		Confidentiality	CAPEC - CAPEC-37: Retrieve Embedded Sensitive Data (Version 3.9)
Tampering	G 0.20	Information or products from an unreliable source		Integrity	CAPEC - CAPEC-185: Malicious Software Download (Version 3.9)
Tampering	G 0.21	Manipulation of hardware or software		Integrity	CAPEC - CAPEC-515: Hardware (Version 3.9) CAPEC - CAPEC-437: Supply Chain (Version 3.9)

Tampering	G 0.22	Manipulation of information		Integrity	Access protection in case of absence
Tampering	G 0.23	Unauthorized intrusion into IT systems		Integrity	Access protection on the customer side; Reduction of interfaces
Denial of Service	G 0.24	Destruction of devices or data carriers		Availability	CAPEC - CAPEC-547: Physical Destruction of Device or Component (Version 3.9)
Denial of Service	G 0.25	Failure of equipment or systems		Availability	Backup recovery process; Tests on the customer side
	G 0.26	Malfunction of equipment or systems			A.7.4 A.7.2c
Denial of Service	G 0.27	Lack of resources		Availability	CAPEC - CAPEC-130: Excessive Allocation (Version 3.9)
	G 0.28	Software vulnerabilities or bugs			Vulnerability management; SBOM; PSIRT
	G 0.29	Violation of laws or regulations			not covered
Spoofing	G 0.30	Unauthorized use or administration of devices and systems		Authentication	CAPEC - CAPEC-114: Authentication Abuse (Version 3.9) CAPEC - CAPEC-216: Communication Channel

					Manipulation (Version 3.9)
Repudiation	G 0.31	Incorrect use or administration of devices and systems		Account ability	CAPEC - CAPEC-180: Exploiting Incorrectly Configured Access Control Security Levels (Version 3.9)
Elevation of Privilege	G 0.32	Abuse of permissions		Authoriz ation	CAPEC - CAPEC-122: Privilege Abuse (Version 3.9)
Denial of Service	G 0.33	Staff shortages		Availabili ty	is the responsibility of the customer
Denial of Service	G 0.34	Attack		Availabili ty	not covered
	G 0.35	Coercion, extortion or corruption			CAPEC - CAPEC-444: Development Alteration (Version 3.9) CAPEC - CAPEC-447: Design Alteration (Version 3.9)
Information Disclosure	G 0.36	Identity theft		Confiden tiality	CAPEC - CAPEC-151: Identity Spoofing (Version 3.9)
Repudiation	G 0.37	Denial of actions		Account ability	CAPEC - CAPEC-268: Audit Log Manipulation (Version 3.9)
Information Disclosure	G 0.38	Misuse of personal data		Confiden tiality	not applicable

Tampering	G 0.39	Malware		Integrity	CAPEC - CAPEC-549: Local Execution of Code (Version 3.9)
Denial of Service	G 0.40	Denial of Service		Availability	Denial of Service, Technique T0814 - ICS MITRE ATT&CK®
Denial of Service	G 0.41	Sabotage		Availability	not covered
	G 0.42	Social Engineering			IT security concept of the customer
Tampering	G 0.43	Importing messages		Integrity	CAPEC - CAPEC-94: Adversary in the Middle (AiTM) (Version 3.9) CAPEC - CAPEC-21: Exploitation of Trusted Identifiers (Version 3.9)
Environment	G 0.44	Unauthorized intrusion into premises			not covered
Denial of Service	G 0.45	Loss		Availability	Configuration management; Backup Recovery
Tampering	G 0.46	Loss of integrity of sensitive information		Integrity	Logging; Acls
	G 0.47	Harmful side effects of IT-based attacks			

Determination of measures based on the protection objective and threats

On the basis of the identified threats, the Required Essential Requirements are determined on the basis of the protection objective.

Threat	Description	Protection objective	62443-4-2 FR
Spoofing	Pretending to be something or someone else	Authentication	Identification and Authentication Control (IAC): Ensures that entities are properly authenticated, preventing spoofing attacks.
Tampering	Modifying data or code	Integrity	System Integrity (SI): Protects the system from unauthorized changes, addressing tampering threats.
Repudiation	Denying actions or transactions	Accountability	Use Control (UC): Ensures that actions are performed by authorized users, which helps in tracking and preventing repudiation. Timely Response to Events (TRE): Ensures that security events are logged and responded to, aiding in non-repudiation.
Information Disclosure	Unauthorized access to information	Confidentiality	Data Confidentiality (DC): Ensures that data is accessible only to authorized entities, preventing unauthorized information disclosure. Restricted Data Flow (RDF): Controls the flow of data within the system to prevent unauthorized access

Denial of Service	Exhausting resources to make a service unavailable	Availability	Resource Availability (RA): Ensures that resources are available when needed, mitigating denial of service attacks. Timely Response to Events (TRE): Ensures prompt response to security events, helping to mitigate the impact of denial of service attacks
Elevation of Privilege	Gaining unauthorized access to higher privileges	Authorization	Identification and Authentication Control (IAC): Ensures proper authentication, preventing unauthorized elevation of privileges. Use Control (UC): Restricts access to authorized users, preventing unauthorized privilege escalation

Specifications / Requirements

Setting the System under consideration (SUC)

Clear identification and description of the system

The basis of the threat analysis is the clear description of the system and its limits. The following information must be available:

- Description of the system
 - Overview Architecture
 - Overview of interfaces (internal and external) and the available communication protocols
 - Overview of critical resources and "assets"
 - Determination of the scope of application and the target group
- Intended use / reasonably foreseeable misuse
- Description of the different phases of the overall life cycle and their dependencies
- Determination of users

- Operator
- Maintenance personnel or technicians
- Determination of what is not part of the system
- Setting the Trust Limits of the SUC

Determination of the limits of low-voltage equipment

In accordance with the requirements of CENELEC Guide 32 (1st edition, 2014-07), the following basic assumptions (Section 5) are made and taken into account for the IT security-relevant risk assessment.

- The low-voltage equipment considered in this risk assessment is intended for use in a safe environment in accordance with IEC EN 62443-1-1.
- The user must carry out a risk assessment for the use of the low-voltage equipment corresponding to the use
- As part of a system, a low-voltage equipment cannot provide all the protections against IT security-related risks at the product level.
- For the proper functioning of IT security-relevant functions, measures must be taken on the system side and functions must be provided.
- The user must take measures that ensure the physical protection of the low-voltage equipment based on the risk analysis

Classification of the SUC

Device classification

[☐ Threat Analysis | Device classification](#)

Data classification

[☐ Threat Analysis | Data classification](#)

[☐ Threat Analysis | Memory Classification \(Volatility Document\)](#)

Definition of the operating environment of the SUC (exposure)

[☐ Threat Analysis | Exposure:](#)

Definition of communication options and access requirements

[☐ Threat Analysis | Communication Skills/Access:](#)

Documentation

All information on the determination of the component must be included in the technical documentation.

The information becomes the basis for all safety-relevant information for the system integrator or the end customer.

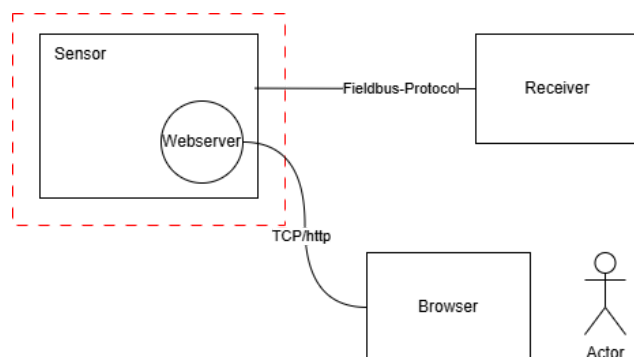
Consideration of the SUC and all interfaces for possible vulnerabilities according to the following threats (STRIDE method)

For each interface of the SUC, the threats of the "[Global Threat List](#)" are applied. It should be noted here that parts of the hazard list are already considered and evaluated as part of the equipment risk analysis. When considering the respective interface, all possible threats must be taken into account (security-in-depth strategy).

Each identified threat is entered in a risk register with its severity, probability of occurrence, endangered protection goal and the necessary expertise or resources. It is also important to consider in which phase of life the interface is available or by whom it is used. It is important in threat analysis that different situations can occur in each phase of the life of the SUC. For example, a hazard during commissioning cannot occur during operation.

- i** All necessary requirements identified and their risk determined in the course of the threat analysis must be incorporated into the system specification by the responsible technical manager. The technical manager is responsible for the treatment and for the necessary countermeasures.

Example



The example shown here involves a web server that is available from outside the "scope" of the component for access. From the threat list, we now remove the threat G0.14 "Information spying (espionage)" for the web server interface. From the STRIDE method, we have an "information disclosure" threat with an attack on the protection goal of confidentiality. One of the most common attacks in this category is sniffing, for which we look at the definition of CAPEC-157 (Common Attack Pattern Enumerations and Classifications). The CAPEC description provides us

with information on whether the attack is applicable to the example scenario. In this case, it is the CAPEC ID 158, "Sniffing Network Traffic". The detailed CAPEC gives us detailed information about the Typical Severity (MEDIUM) of a successful attack and the Skills Required (LOW) and requirements that are necessary for the attack. In addition to the possible impact on the example object, the existing vulnerability "Missing Encryption of Sensitive Data" CWE-ID 311 (CWE, Common Weakness enumeration) is also identified. The CWE provides developers with helpful information on how to implement a possible countermeasure to the vulnerability. Another important factor for risk assessment is also included in the CWE, the likelihood of exploit (HIGH).

For the risk assessment, the severity and probability of exploitation for the risk assessment are determined.

The following information is included in the risk assessment.

- The threat of "spying on information (espionage)"
- The vulnerability that can lead to the threat: "Missing Encryption of Sensitive Data"
- The severity of the threat "MEDIUM" and the probability of occurrence "HIGH"

According to the risk assessment, appropriate **countermeasures** must then be provided (according to [BSI, Treat Risks](#)):

- **Risk aversion**

The risks can be avoided by restructuring the information network in such a way that the threat can no longer become effective. This is a good idea, for example, if countermeasures are possible, but involve too much effort and at the same time the risk cannot be accepted.

- **Risk reduction** (risk modification) through further security measures

The risks can be reduced by additional, higher-quality security measures.

- **Risk transfer**

The risks are shifted. By taking out insurance or outsourcing the risky task to an external service provider, for example, a possible financial loss can be passed on (at least in part) to third parties.

- **Risk acceptance**

The risks can be accepted, either because the hazard could only lead to damage under extremely special conditions, because there are no sufficiently effective countermeasures known or because the effort required for possible protective measures is unreasonably high.

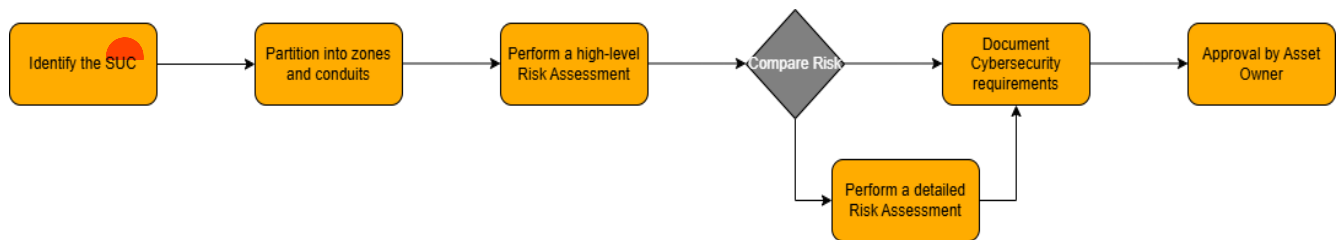
The necessary measure is included in the risk register.



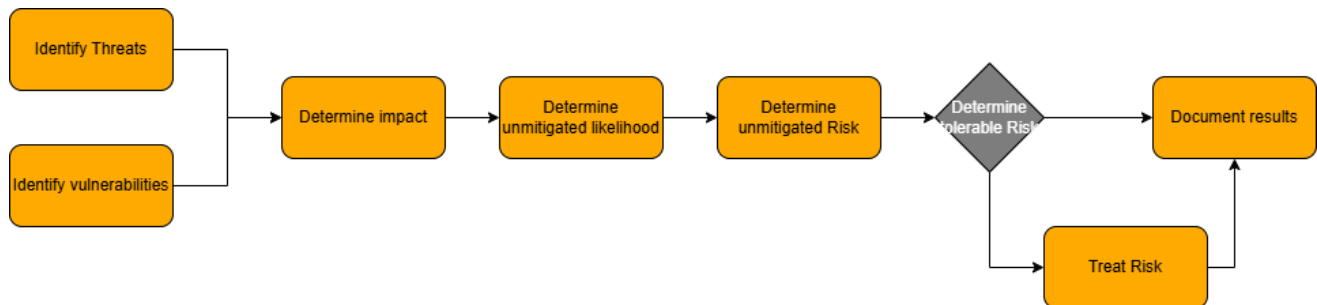
⚠ The Risk definition should be made very carefully.

Diagram Threat and Risk Analysis (High-Level and Detailed Observation)

Threat and Risk Analyses



Detailed Risk Assessment



Change history

Version	Date	Comment
Current version (v. 2)	June 23, 2025 08:10	Matthias Schmidt
v. 1	May 26, 2025 08:40	Matthias Schmidt

Contributors

User	Workings	Comments	Keywords
Matthias Schmidt	2	0	0

Determine the typical severity, prerequisites, required skills and resources and determine the risk (see [Risk Assessment](#)).

Device Class Definition

The following device classes including their properties are available:

Type	Exposure	Communication skills/access
------	----------	-----------------------------

Embedded Device	Level 1 Fieldbus Level	Component is not accessible from the outside via the network and is protected from unauthorized access in the machine
		Component/cabling is not accessible via the operator's network (Level 4). Access to external interfaces (USB, user interface) possible
		Component communicates with other components in the operator network
		Component has direct access to the Internet.
	Level 2 Production or machine network of the operator	The component is not accessible from the outside via the network and is protected from unauthorized access in the machine.
		Component is not accessible via the operator network, but access to external interfaces (USB, user interface) is possible.
		Component communicates with other components in the operator network
		Component has direct access to the Internet.
Embedded sensor / actuator with analog, digital interface	Level 1 Fieldbus Level	The component is not accessible from the outside via the network and is protected

		from unauthorized access in the machine.
Embedded sensor / actuator with fieldbus interface (protocol-based), incl. IO-Link protocol	Level 1 Fieldbus Level	The component is not accessible from the outside via the network and is protected from unauthorized access in the machine.
	Level 1 fieldbus level with external interface	Component/cabling is not accessible via the operator's network (Level 4). Access to external interfaces (USB, user interface) possible
	Level 1 fieldbus level with external interface in the "Local Area Network" but no access to the "Wide Area Network"	Component communicates with other components in the operator network
Communication modules	Level 1 Fieldbus Level	Component communicates with other components in the operator network
		Component has direct access to the Internet.
	Level 2 Production or machine network of the operator	Component communicates with other components in the operator network
		Component has direct access to the Internet.
Network Device	Level 1 Fieldbus Level	
	Level 2 Production or machine network of the operator	

Embedded sensor / actuator with analog, digital interface

Embedded sensors/actuators have no protective measures against cyber security attacks. The analog interface transmits a 4-20mA signal to the higher-level component. An embedded sensor/actuator with a digital interface uses a 2.5V switching signal to connect to the higher-level component. Due to the characteristics of pure signal transmission and the lack of parameterizability, no cyber security measures can be taken. In accordance with the risk assessment, protective measures against sabotage must be implemented.

Embedded sensor / actuator with fieldbus interface (protocol-based), incl. IO-Link protocol
without external interface

When using fieldbus protocols or interfaces, fundamental limitations in cyber security threat analysis must be taken into account.

Standard fieldbus protocols are designed to transmit data reliably and, if necessary, deterministically. Regardless of the protocol structure and the connection topology, availability according to the current state of the art is the decisive protection goal of these protocols and interfaces. As part of an overall system, measures must be taken by the integrator or operator to ensure the availability of the component and communication between them.

The protection of parameterization is the responsibility of the higher-level system or parameterization software

Level 1 fieldbus level with external interface

For components with an external interface, separate protective measures must be taken. In addition to the consideration of the fieldbus interface, all external interfaces must be considered separately.

Based on the STRIDE method, the following threats to the web server interface must be considered and assessed according to the assumed risk.

Title	Category	Interaction	Description
Cross Site Scripting	Tampering	HTTP	The web server 'Web Server' could be a subject to a cross-site scripting attack because it does not

			sanitize untrusted input.
Elevation Using Impersonation	Elevation Of Privilege	HTTP	Web Server may be able to impersonate the context of Browser Client in order to gain additional privilege.
Elevation by Changing the Execution Flow in Web Server	Elevation Of Privilege	HTTP	An attacker may pass data into Web Server in order to change the flow of program execution within Web Server to the attacker's choosing.
Web Server May be Subject to Elevation of Privilege Using Remote Code Execution	Elevation Of Privilege	HTTP	Browser Client may be able to remotely execute code for Web Server.
Data Flow HTTP Is Potentially Interrupted	Denial Of Service	HTTP	An external agent interrupts data flowing across a trust boundary in either direction.
Potential Process Crash or Stop for Web Server	Denial Of Service	HTTP	Web Server crashes, halts, stops or runs slowly
Weak Credential Transit	Information Disclosure	HTTP	Credentials on the wire are often subject to sniffing by an attacker. Are the credentials re-usable/re-playable? Are credentials

			included in a message? For example, sending a zip file with the password in the email. Use strong cryptography for the transmission of credentials. Use the OS libraries if at all possible, and consider cryptographic algorithm agility, rather than hardcoding a choice.
Data Flow Sniffing	Information Disclosure	HTTP	Data flowing across HTTP may be sniffed by an attacker. Depending on what type of data an attacker can read, it may be used to attack other parts of the system or simply be a disclosure of information leading to compliance violations. Consider encrypting the data flow.
Potential Data Repudiation by Web Server	Repudiation	HTTP	Web Server claims that it did not receive data from a source outside the trust boundary. Consider using logging or auditing to record the source, time, and

			summary of the received data.
Potential Lack of Input Validation for Web Server	Tampering	HTTP	Data flowing across HTTP may be tampered with by an attacker. This may lead to a denial of service attack against Web Server or an elevation of privilege attack against Web Server or an information disclosure by Web Server. Failure to verify that input is as expected is a root cause of a very large number of exploitable issues. Consider all paths and the way they handle data. Verify that all input is verified for correctness using an approved list input validation approach.
Spoofing the Web Server Process	Spoofing	HTTP	Web Server may be spoofed by an attacker and this may lead to information disclosure by Browser Client. Consider using a standard authentication mechanism to identify

			the destination process.
Spoofing the Browser Client Process	Spoofing	HTTP	Browser Client may be spoofed by an attacker and this may lead to unauthorized access to Web Server. Consider using a standard authentication mechanism to identify the source process.

Level 1 fieldbus level with external interface in the "Local Area Network" but no access to the "Wide Area Network"

Equivalent to the requirements of the "Level 1 fieldbus level with external interface", the technical requirements also apply to "Level 1 fieldbus level with external interface in the "Local Area Network" but no access to the "Wide Area Network"".

Embedded Device

CENELEC Guide32 ReferencingSafety aspectCENELEC Guide 32References safety aspectsA.1, A.2, A.3 Information	Reference to standards IEC EN 62443	Description	Result : PASSED FAILED Deviation
A.8	IT Security		
a) Protection against accidental or accidental breach of security;			

b) Protection against deliberate breach of security by simple means and limited resources, general knowledge and low motivation;			
c) Protection against deliberate breach of safety by modern means and moderate resources, specific knowledge of the appropriate resources and moderate motivation;			
d) Protection against deliberate breach of safety by means of modern means and advanced resources, specific knowledge of the relevant resources and high motivation.			